

ARGOS: Herramienta para la simulación de rutas de ataque en entornos de conciencia cbersituacional

Carmen Sánchez-Zas, Samuel García Sánchez, Xavier Larriva-Novo, Sonia Solera-Cotanilla,
Oscar Jover-Walsh, Víctor A. Villagrà

Universidad Politécnica de Madrid (UPM). DIT, ETSI Telecomunicaciones. Avda. Complutense 30, 28040 Madrid
carmen.szas@upm.es, samuel.garcia.sanchez@alumnos.upm.es, xavier.larriva.novo@upm.es,
sonia.solera@upm.es, oscar.jwalsh@upm.es, victor.villagra@upm.es

Resumen—En un contexto donde las amenazas de ciberseguridad son cada vez más sofisticadas, este artículo propone una solución para la prevención de ciberataques mediante la visualización del camino de ataque. Esto facilita la identificación de vulnerabilidades y la evaluación del impacto potencial de una intrusión, permitiendo a los equipos de seguridad anticiparse a posibles amenazas y fortalecer la protección de los sistemas. En esta propuesta se simula una ruta de ataque partiendo de técnicas definidas en MITRE ATT&CK y, a continuación, se representa gráficamente el posible recorrido que un adversario seguiría para comprometer un activo vulnerable desde cualquier punto de entrada al sistema. Al obtener acceso inicial a una infraestructura organizacional, un atacante puede moverse lateralmente entre activos hasta alcanzar los elementos más críticos. Para tratar de evitarlo se ha desarrollado una herramienta denominada ARGOS, presentada como un enfoque proactivo para mejorar la ciberseguridad en entornos de conciencia cbersituacional.

Index Terms—Ruta de ataque, Ciberseguridad, TTPs, Cadenas de Markov, MITRE ATT&CK.

Tipo de contribución: *Investigación original (límite 8 páginas)*

I. INTRODUCCIÓN

Desde hace tiempo, las organizaciones y los gobiernos se enfrentan constantemente a posibles ataques de seguridad [1]. Sin embargo, la necesidad de una ciberdefensa de próxima generación se ha vuelto aún más urgente en esta era en la que las superficies de ataque que los ciberdelincuentes pueden explotar han crecido a un ritmo alarmante. Este rápido crecimiento deriva del aumento de la complejidad en los sistemas empresariales y la adopción masiva de servicios en la nube y dispositivos conectados [2]. En este contexto, la ciberdefensa basada en el análisis predictivo resulta más proactiva que las tecnologías actuales, que dependen de la detección de intrusiones.

Este nuevo enfoque de ciberdefensa está transformando la manera en que las organizaciones comprenden sus vulnerabilidades y se preparan ante posibles ataques. El *Informe de Situación Ciberseguridad en España 2024* [3] destaca que la adopción de la inteligencia artificial se ha acelerado en el ámbito de la ciberseguridad, proporcionando herramientas de análisis predictivo y detección automatizada de amenazas dentro de los entornos de conciencia cbersituacional. Ya no se trata solo de identificar vulnerabilidades aisladas o puntos débiles, ahora se trata de entender cómo los atacantes pueden encadenar estos puntos débiles para crear un camino de ataque crítico hacia sus activos más valiosos, como los administradores de dominio, bases de datos críticas, controladores de dominio de *Active Directory*, etc.

De este contexto surge esta propuesta, con el que se pretende ofrecer una solución para la prevención de ciberataques mediante la visualización del camino de ataque o *attack path visualization*, que es una representación gráfica de los posibles caminos de ataque que un adversario podría seguir para comprometer un activo desde cualquier punto de entrada en el sistema objetivo. Por ejemplo, una vez que un atacante ha logrado un acceso inicial al entorno organizacional, el camino de ataque muestra la posible ruta que el adversario puede tomar entre los activos para llegar a los elementos más valiosos, como los controladores de dominio.

El enfoque de la propuesta permite identificar los activos más vulnerables y evaluar la severidad de los ataques según rutas de ataque obtenidas de la simulación e integrar estos resultados con estrategias de mitigación, proporcionando recomendaciones adaptadas a los ataques identificados. De esta forma, se ha desarrollado un prototipo de esta propuesta en la herramienta ARGOS que contribuye a la mejora en la toma de decisiones en relación con la gestión de riesgos, un concepto clave en los entornos de conciencia cbersituacional.

A lo largo del documento presentaremos el entorno de la propuesta y los conceptos principales en los que se basa el desarrollo. A continuación, detallaremos la arquitectura de la herramienta, el desarrollo y los resultados obtenidos. En la sección I se presenta el entorno del trabajo. A continuación, en la sección II, se presentan trabajos anteriores que tratan la misma problemática. En la sección III se definen brevemente los conceptos teóricos relacionados con el proyecto. La arquitectura de ARGOS se define en la sección IV y se desarrolla en la sección V. Finalmente, la validación y los resultados obtenidos se presentan en la sección VI. Finalmente, las conclusiones y líneas futuras se presentan en la sección VII.

II. TRABAJOS RELACIONADOS

La simulación de rutas de ataque en ciberseguridad mediante modelos probabilísticos ha sido un objetivo recurrente en la investigación de seguridad. Ha sido ampliamente estudiado para mejorar la gestión de riesgos y la identificación de activos críticos. En particular, el uso de cadenas de Markov ha demostrado ser una herramienta eficaz para estimar rutas de ataque y apoyar a la toma de decisiones en seguridad informática. En [4], los autores plantean el uso de HMM siguiendo una mezcla de distribuciones gaussianas (*Gaussian Mixture Hidden Markov Model* o GM-HMM) para conseguir detectar ataques multipaso, es decir, una secuencia de ataques.

Holgado et al. presentan en [5] un sistema de predicción de ataques multietapa basado en modelos ocultos de Markov

(HMM). Este enfoque modela la progresión de ataques partiendo de alertas que provienen de sistemas de detección de intrusiones (IDS), con el objetivo de predecir las próximas acciones de los atacantes y mejorar las estrategias de defensa. Sin embargo, se centra en la predicción, sobre todo centrada en ataques DDoS, pero no se integra en una herramienta enfocada en la gestión de riesgos y la protección específica de activos.

Siguiendo con la aplicación de HMM en este ámbito, Amin et al. combinan en [6] esta herramienta con técnicas de ciberengaño para frustrar el movimiento lateral de atacantes dentro de la red. Con un enfoque a la vez reactivo y proactivo, en primer lugar predicen la ruta de ataque más probable partiendo de alertas de IDS y determinan el despliegue óptimo de nodos señuelo a lo largo de esa ruta. Mediante la planificación parcialmente observable de Monte-Carlo (POMCP) definen acciones defensivas para bloquear al atacante en caso de que no siga la ruta calculada. Su investigación, partiendo de una base muy similar a la que se va a presentar en este documento, propone un enfoque hacia la defensa activa en lugar de la evaluación del impacto de los ataques en activos y la gestión de riesgos. Además, en [7] los autores tratan de predecir ataques y la familia a la que pertenecen mediante HMM. El objetivo es generar una secuencia de estados que correspondan con las etapas del ataque *Action Spoofing*, aunque sería generalizable a cualquier tipo de ataque.

Los autores de [8], por su parte, proponen un sistema basado en grafos de ataque y cadenas de Markov para modelar escenarios de ataque. Su metodología permite identificar los posibles caminos entre un origen y un destino dentro de una red y calcula la probabilidad de ataque. Finalmente, calcula el riesgo total del ataque, lo que le permite evaluar el nivel de peligro frente al grado de penetración del ataque. En este caso, los activos más vulnerables no se identifican y por tanto no se llega a evaluar la efectividad de diferentes estrategias de mitigación.

Otro enfoque en el cálculo de patrones de ataque consiste en considerar la variable temporal, como en [9], donde los autores presentan una herramienta capaz de computar todas las rutas de ataque iterando sobre las posibles duraciones de los posibles ataques. Los autores plantean añadir sobre los árboles de ataque utilizados para calcular las rutas, sellos temporales mediante *Boolean logic Driven Markov Processess* (BDMP).

El estudio sobre los trabajos relacionados han permitido demostrar que las cadenas de Markov son una herramienta clave para determinar qué activos son críticos, evaluar la severidad de los ataques, definiendo las respuestas más adecuadas para mitigar de forma proactiva las amenazas.

Los trabajos anteriormente analizados han contribuido notablemente al desarrollo de modelos predictivos en seguridad, pero su integración con enfoques de gestión de riesgos sigue siendo un desafío. A diferencia de estos, la herramienta que se propone en esta investigación contiene un modelo para la simulación de rutas de ataque utilizando cadenas de Markov con el objetivo de estimar qué movimientos son los más probables dentro de la red y utilizar esta información como complemento a la gestión de riesgos, lo que supone una ventaja con respecto a otros enfoques tradicionales.

III. MARCO TEÓRICO

III-A. MITRE ATT&CK

MITRE ATT&CK (*Adversarial Tactics, Techniques, and Common Knowledge*) [10] es una base de conocimientos universalmente accesible y continuamente actualizada para modelar, detectar, prevenir y combatir amenazas de ciberseguridad basándose en el comportamiento conocido de los ciberdelincuentes adversarios. Creado por MITRE Corporation, este marco de referencia ofrece una visión estructurada de las tácticas y técnicas empleadas por los atacantes en diferentes fases de una intrusión. Su principal objetivo es proporcionar a organizaciones, analistas de seguridad y profesionales de IT (*Information Technology*) una herramienta para comprender, detectar y mitigar amenazas cibernéticas de manera más efectiva.

El marco se organiza en matrices, que clasifican tácticas y técnicas en función de su propósito y cómo se relacionan con las etapas de un ataque. Las tácticas representan las metas o propósitos generales que los atacantes buscan alcanzar durante cada fase del ataque, como obtener acceso inicial, moverse lateralmente por la red o exfiltrar datos. Por otro lado, las técnicas describen los métodos específicos que los atacantes emplean para lograr las tácticas, por ejemplo, el aprovechamiento de vulnerabilidades o la ejecución de scripts maliciosos.

III-B. Cadenas de Markov

Una cadena de Markov [11] es un modelo matemático utilizado para describir sistemas que evolucionan de manera secuencial, donde la probabilidad de transición entre estados depende únicamente del estado actual y no del historial previo. Este principio se conoce como la propiedad de Markov.

Las cadenas de Markov son particularmente útiles para modelar y analizar procesos estocásticos, es decir, aquellos que involucran incertidumbre. Su capacidad para representar dinámicas donde el futuro depende solo del presente las hace valiosas en áreas como la predicción, la identificación de patrones de comportamiento y la simulación de escenarios en distintos contextos.

Una cadena de Markov consta de tres elementos principales: los estados, que representan las posibles condiciones del sistema (por ejemplo, “soleado”, “lluvioso” o “nublado” en un modelo climático); las transiciones, que describen los cambios entre estados con ciertas probabilidades; y la matriz de transición, que indica la probabilidad de pasar de un estado a otro, donde cada fila representa un estado actual y cada columna un estado futuro. Un estado es absorbente si, una vez alcanzado, no se puede abandonar, mientras que el estado inicial es aquel en el que se encuentra el sistema al inicio del análisis.

III-C. Rutas de ataque

Una ruta de ataque [12] es una representación visual del camino que un atacante podría seguir para explotar debilidades en un sistema y comprometer activos críticos. Este concepto, clave en la ciberseguridad, no solamente permite analizar vulnerabilidades aisladas, sino también cómo estas se interconectan para formar un trayecto explotable.

Su objetivo principal es ayudar a las organizaciones a identificar, priorizar y mitigar riesgos, abordando las amenazas

desde la perspectiva del atacante. En lugar de centrarse únicamente en solucionar vulnerabilidades individuales, el análisis de rutas de ataque proporciona un enfoque estratégico para visualizar el contexto completo de los riesgos, lo que resulta fundamental para proteger activos esenciales.

III-D. Bases de datos orientadas a grafos

Una ruta de ataque pierde gran parte de su potencial si no se visualiza correctamente. La visualización de rutas de ataque [13] es una herramienta poderosa que, mediante el uso de grafos, permite mapear los caminos que un atacante podría seguir dentro de una red, identificando conexiones entre activos, configuraciones erróneas y vulnerabilidades.

Esta representación visual facilita la priorización de recursos, ya que permite identificar los trayectos que conducen a activos críticos, como controladores de dominio o bases de datos sensibles. Así, la información sobre riesgos se transforma en una estrategia clara de mitigación.

Para mapear estas rutas de manera efectiva, se utilizan bases de datos de grafos, que representan de forma estructurada y visual la interconexión entre activos, vulnerabilidades y posibles movimientos de un atacante dentro de una red. Estas bases de datos se componen de nodos o vértices, que representan elementos individuales del sistema, y aristas o relaciones, que reflejan las conexiones entre ellos.

A diferencia de las bases de datos tradicionales, que organizan la información en tablas y requieren consultas complejas para analizar relaciones entre datos, las bases de datos de grafos están diseñadas para manejar interconexiones de manera eficiente. Este aspecto las hace especialmente útiles para modelar escenarios de ataque, ya que permiten identificar caminos críticos con mayor rapidez y precisión.

IV. ARQUITECTURA DE ARGOS

El diseño de la propuesta para la simulación de rutas de ataque se muestra en la Figura 1, cuya arquitectura se implementa en la herramienta ARGOS.

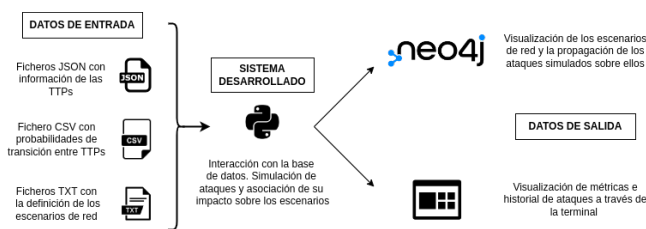


Figura 1. Diagrama de la arquitectura

La información sobre Tácticas, Técnicas y Procedimientos (TTPs) se extrae de la matriz empresarial de MITRE ATT&CK y se gestiona mediante archivos en formatos .json, y .csv, lo que facilita la actualización y la adaptación a nuevas amenazas sin necesidad de modificar la estructura del sistema.

Los escenarios de red se definen y cargan desde ficheros de texto que contienen las relaciones y configuraciones de los activos en un formato interpretable por Neo4j. Esto permite modelar la infraestructura de la red de forma escalable, pudiendo adaptarse a diferentes situaciones. Para la validación

del sistema, se ha desarrollado un breve catálogo de tres simples escenarios: una pequeña oficina corporativa, un escenario de tipo *smart home* y una pequeña planta industrial.

Con toda esta información, el sistema simula rutas de ataque utilizando cadenas de Markov, generando secuencias de técnicas en función de probabilidades definidas. Posteriormente, estas secuencias se integran en el grafo del escenario de red que se haya cargado, permitiendo visualizar la propagación de amenazas y su impacto en los activos comprometidos. Esta asociación se lleva a cabo mediante un mapeo entre las TTPs y los activos afectados, considerando factores como la plataforma y capacidades del activo, los permisos de los que dispone y vulnerabilidades asociadas (CWE/CVE).

Para la visualización en la terminal, se utiliza la librería Rich, que proporciona un dashboard estructurado donde se muestra un resumen del ataque junto a métricas clave acerca de los activos y técnicas involucrados en el mismo, en base a las cuales se calcula una criticidad. Además, el sistema cuenta con un historial de ataques simulados.

V. DESARROLLO

V-A. Modelo de datos

Como ya se ha mencionado, las bases de datos orientadas a grafos permiten representar la información mediante vértices o nodos y aristas o relaciones, lo que resulta especialmente útil para modelar redes informáticas y sus relaciones. Por ello, se ha desarrollado un modelo de datos escalable y flexible, permitiendo la representación tanto de distintos escenarios de red como secuencias de ataque bajo una lógica común.

Para el modelado de los escenarios de red, se han definido dos entidades principales: Usuario y Activo. La entidad Usuario representa las cuentas personales o administrativas que requieren autenticación en distintos elementos de la red. Por otro lado, la entidad Activo agrupa todos los dispositivos y sistemas de la infraestructura, dividiéndose en cuatro subcategorías según su función. Un Servidor representa dispositivos que ejecutan servicios accesibles, mientras que un DispositivoRed incluye equipos de usuario y otros sistemas conectados. Los elementos de seguridad, como *firewalls*, VPNs o sistemas IDS, se agrupan bajo la categoría DispositivoSeguridad. Finalmente, el software instalado en servidores o estaciones de trabajo se modela como Aplicación.

Cada nodo en el grafo cuenta con atributos en formato clave-valor, lo que permite almacenar información detallada sobre sus características. Estos atributos son fundamentales para asociar los activos con posibles vulnerabilidades y técnicas de ataque, facilitando el análisis de seguridad.

Las relaciones entre nodos son esenciales para modelar la conectividad y las dependencias dentro de la red. Se han definido cuatro tipos principales de relaciones entre los elementos presentes en los escenarios de red: CONEXIÓN, que indica la comunicación entre dos activos a través de un puerto; PROTECCIÓN, que señala cuando un activo está resguardado por un dispositivo de seguridad; AUTENTICACIÓN, que representa la necesidad de un usuario de autenticarse en un activo; y ALOJAMIENTO, que vincula una aplicación o servicio con el servidor donde está instalado.

Por otro lado, para modelar los ataques dentro del sistema, se ha definido la entidad Técnica, que representa cada una

de las técnicas de la matriz empresarial de MITRE ATT&CK utilizadas en una secuencia de ataque. Esta entidad se asocia con los activos vulnerables a través de atributos específicos. Además, se han definido dos relaciones clave para representar la progresión de los ataques: TRANSICIÓN, que indica la sucesión entre técnicas dentro de una secuencia de ataque, y EXPLOTACIÓN, que muestra la afectación de un activo por una técnica específica. En la Figura 2 se muestran todos los nodos y relaciones descritos.

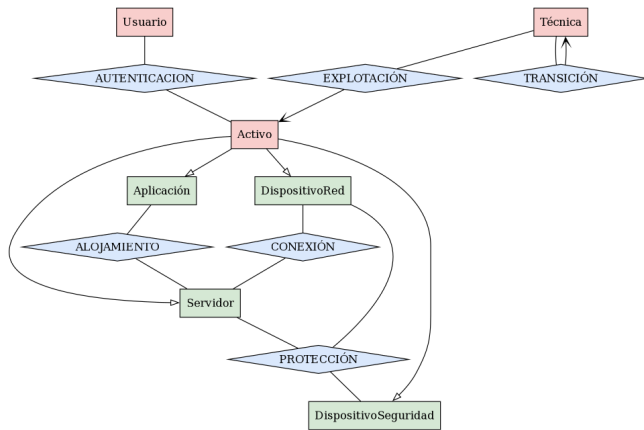


Figura 2. Modelo de datos empleado en ARGOS

V-B. Funcionamiento general

ARGOS es una herramienta de línea de comandos desarrollada en Python que permite analizar cómo una serie de TTPs pueden afectar un entorno de red simulado. Su principal objetivo es proporcionar una manera estructurada y automatizada de modelar ciberataques y visualizar su impacto en infraestructuras digitales.

ARGOS trabaja sobre una base de datos en Neo4j, que ha de ser configurada previamente. Para operar, ARGOS cuenta con cuatro comandos principales. El comando `prepare` permite cargar un escenario de red en la base de datos, transformándolo en un grafo dentro de Neo4j que representa activos y sus conexiones. Los escenarios se leen desde un archivo de texto ubicado en la carpeta `scenarios`. Estos archivos están escritos en un lenguaje denominado *Cypher*.

Cypher es el lenguaje de consulta diseñado específicamente para trabajar con grafos en Neo4j. Utiliza una sintaxis inspirada en SQL pero optimizada para manejar nodos y relaciones. De esta forma, es posible la realización de consultas y operaciones complejas sobre los grafos.

Cada escenario contiene información sobre los activos que lo componen (servidores, estaciones de trabajo, dispositivos, etc.) y sus características clave, como los sistemas operativos que utilizan, los permisos que poseen y las vulnerabilidades que podrían explotarse, utilizando el modelo de datos descrito en la sección V-A.

Antes de ejecutar cualquier simulación, ARGOS requiere que se cargue un escenario de red en la base de datos. Luego, el comando `attack` genera una secuencia de ataque basada en un modelo de Cadenas de Markov, que permite generar secuencias de técnicas de manera probabilística, y la ejecuta sobre el escenario cargado. Partiendo de una técnica seleccionada de manera aleatoria, la Cadena de Markov implementada

permite calcular el siguiente estado únicamente a partir del estado actual utilizando las probabilidades de transición entre estados, definidas en el fichero `transitions.csv`. Esto significa que cada técnica utilizada en el ataque tiene una probabilidad de llevar a la siguiente, asegurando que las transiciones entre estados sean coherentes con patrones de ataque reales. De esta forma, ARGOS puede modelar la progresión de un ciberataque desde su punto de inicio hasta su posible finalización, considerando factores como la probabilidad de éxito de cada técnica y las condiciones del escenario.

Una vez generada la secuencia de ataque, ARGOS asocia cada técnica con los activos a los que afecta dentro del escenario cargado. Para ello, analiza características como los sistemas operativos presentes, los permisos disponibles y las vulnerabilidades conocidas, que habían sido definidas como atributos en los nodos. Si un activo cumple con los criterios necesarios, se establece una relación entre la técnica de ataque y el activo comprometido, reflejando el impacto del ataque en la red simulada. En la Figura 3, se presentan los atributos que caracterizan cada entidad, así como las condiciones para que se produzca una relación de tipo EXPLOTACIÓN entre ellos.

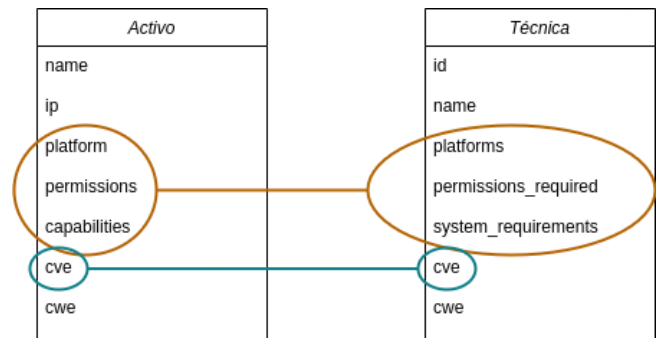


Figura 3. Condiciones de explotación de una técnica sobre un activo

La lógica utilizada para vincular las técnicas de ataque con los activos afectados se basa en la ejecución de una consulta Cypher sobre la base de datos Neo4j. Esta asociación se puede dar mediante dos condiciones. El filtro principal, representado de color naranja en la Figura 3, exige que el activo se ejecute en alguna de las plataformas afectadas por la técnica y, además, que cumpla con dos condiciones simultáneas: que posea al menos un permiso que coincida con los permisos requeridos por la técnica y que cuente con alguna capacidad del sistema que corresponda con los requisitos de la técnica. Esta condición compuesta refleja la necesidad de que el activo no solo opere en la plataforma objetivo, sino que también cumpla con las condiciones de acceso y recursos que la técnica requiere para ser aplicada. Adicionalmente, como alternativa a este conjunto de condiciones, la consulta también considera un segundo filtro (representado en color azul) para los activos que tengan vulnerabilidades identificadas por los CVEs relacionados con la técnica, permitiendo así que la técnica explote directamente vulnerabilidades conocidas.

Finalmente, el comando `history` permite consultar los ataques realizados previamente, mientras que el comando `clean` limpia la base de datos, eliminando cualquier información previa para realizar nuevas simulaciones desde cero.

VI. VALIDACIÓN

En esta sección, se presenta la validación de la herramienta ARGOS y los resultados obtenidos a partir de su ejecución. El proceso de validación se divide en varios pasos, que incluyen la carga de escenarios, la ejecución de simulaciones de ataque y el análisis de los resultados obtenidos, tal y como se muestra en el diagrama de ejecución de la Figura 4.

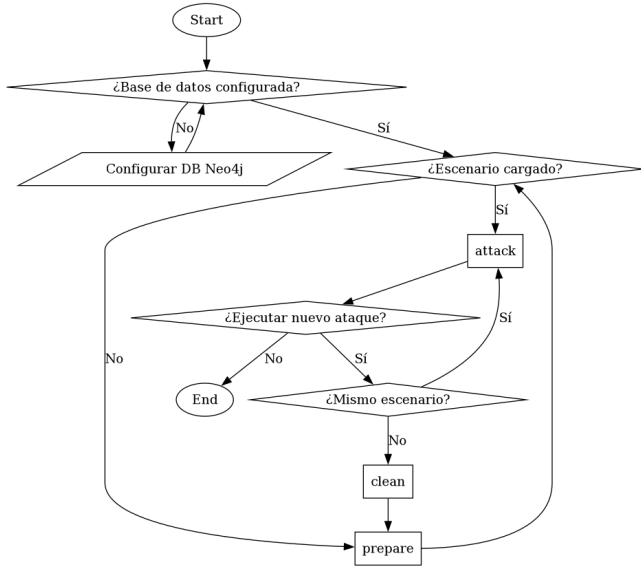


Figura 4. Diagrama de flujo de ARGOS

El primer paso antes de utilizar ARGOS es configurar e iniciar la base de datos. Una vez configurada, es necesario abrir la consola de Neo4j, ya que es donde se mostrarán los grafos correspondientes a la ejecución de ARGOS. Una vez hecho esto, ya se puede interactuar con la base de datos desde la terminal, mediante la interfaz de línea de comandos. El comando a ejecutar para cargar el escenario correspondiente a la oficina corporativa sería el siguiente: `$ python3 argos.py prepare escenarios/oficina.cypher`. Tras ejecutarlo, el programa indica que dicho escenario se ha cargado sin problemas en la base de datos.

Tras este mensaje, en la consola de Neo4j se puede visualizar el escenario cargado en forma de grafo, tal y como se muestra en la Figura 5.

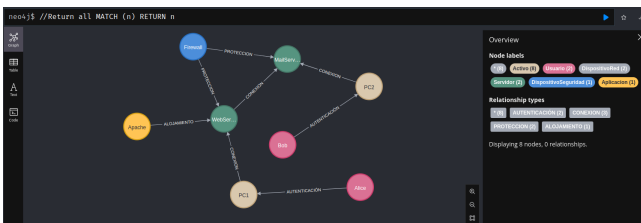


Figura 5. Escenario de oficina corporativa cargado en Neo4j

En este escenario, los usuarios están representados por los nodos Alice y Bob. Alice utiliza un PC Windows con permisos estándar y diversas capacidades que le permiten interactuar con otros activos en la red. El usuario Bob cuenta con Linux en su equipo, donde dispone de permisos de administrador. Tiene instalado el software *Digitaldesign CMS*.

El CVE-2009-3597 afecta a *Digitaldesign CMS* en su versión v0.1, que guarda información sensible en el directorio web raíz con insuficiente control de acceso, lo que permite a los atacantes remotos descargar el fichero de la base de datos a través de una petición directa a `autoconfig.dd`.

Los nodos de tipo servidor son *WebServer* y *MailServer*. *WebServer* corre en Windows con privilegios administrativos y capacidades relacionadas con la ejecución remota y la gestión de archivos y directorios críticos. *MailServer*, basado en Linux, presenta características similares en cuanto a acceso remoto y almacenamiento de información.

El dispositivo de seguridad en la red es un *firewall*, que cumple una función de protección. Cuenta con permisos administrativos y la capacidad de capturar tráfico de red y analizar paquetes, lo que permite monitorear y restringir accesos no autorizados.

También se ha modelado una aplicación, *Apache*, que opera en Linux con permisos administrativos. Esta aplicación tiene acceso a archivos y directorios específicos y presenta vulnerabilidades potenciales debido a software no actualizado.

En cuanto a las relaciones, Alice se autentica en su equipo, el cual accede a *WebServer* mediante el protocolo LDAP, mientras que el equipo utilizado por Bob establece comunicación con *MailServer* utilizando el protocolo SMTP. Además, *WebServer* y *MailServer* están enlazados mediante una conexión en el puerto 25 con protocolo SMTP, lo que indica la comunicación entre estos servicios.

El nodo *Firewall* protege tanto a *WebServer* como a *MailServer*, reforzando la seguridad de la red. Finalmente, *Apache* está alojado en *WebServer*, lo que indica su dependencia de este servidor para operar dentro del entorno web.

Si ahora se ejecuta el comando `$ python3 argos.py attack`, el sistema generará una secuencia aleatoria de técnicas y evaluará su impacto sobre el escenario cargado. Al ejecutar de nuevo la `query MATCH (n) RETURN (n)`, se puede apreciar que la secuencia de ataque generada ha sido insertada y que los nodos y relaciones correspondientes han sido creados sobre el escenario (Figura 6).

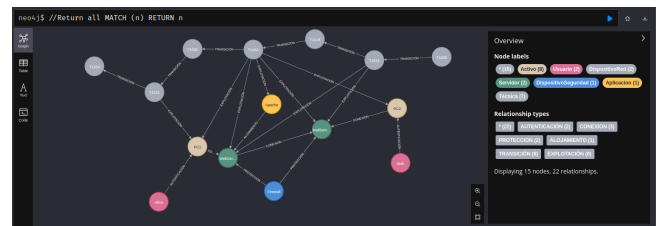


Figura 6. Ataque sobre el escenario de oficina corporativa

Se va a analizar una de las relaciones de explotación creadas, en concreto la que asocia a la técnica T1021 (uno de los nodos de color gris en la Figura 6) con el activo *WebServer* (representado en verde).

Lo primero es verificar que los nodos se han creado correctamente, conteniendo los atributos que los caracterizan. El nodo *MailServer* representa el servidor de correo dentro de la infraestructura de red, es un nodo de tipo *Activo* y subtipo *Servidor*, sus atributos se muestran en la Figura 7.

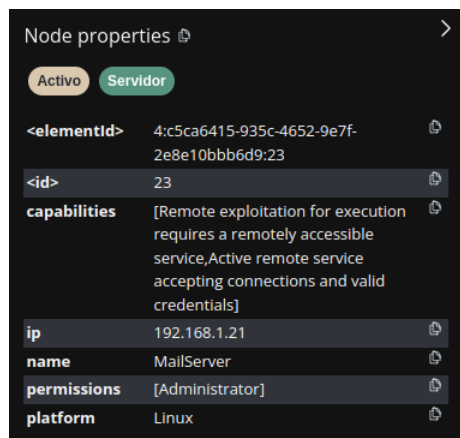


Figura 7. Propiedades del nodo MailServer

Por otro lado, el nodo T1021, de tipo Técnica, representa la técnica *Remote services* de la matriz empresarial de MITRE ATT&CK. Esta técnica describe cómo los adversarios pueden usar cuentas válidas para acceder remotamente a sistemas dentro de una red empresarial que cuenta con un sistema de inicio de sesión centralizado. Si logran credenciales legítimas, los atacantes pueden iniciar sesión en múltiples dispositivos mediante protocolos como SSH o RDP, o incluso en servicios en la nube vinculados al dominio. Sus atributos se pueden apreciar en la Figura 8.

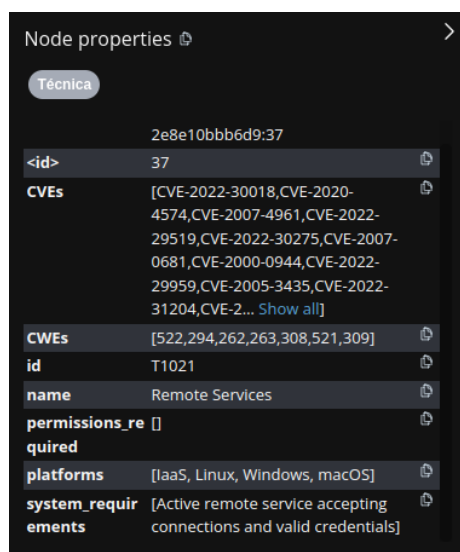


Figura 8. Propiedades del nodo T1021

Al no haber ninguna vulnerabilidad configurada en el atributo `cve` de MailServer, el origen de la relación de EXPLOTACIÓN han de ser los parámetros indicados en naranja en la Figura 3. Si se revisan, se puede apreciar que la plataforma que corre el servidor, Linux, es una de las plataformas afectadas por el sistema. Además, el sistema cuenta con la capacidad *Active remote service accepting connections and valid credentials*, uno de los requisitos necesarios por esta técnica para ser explotada. Finalmente, la técnica no requiere de ningún permiso en concreto para ser explotada con éxito. De hecho, esta técnica se clasifica en la matriz empresarial dentro de la táctica *Lateral Movement*, pues al

obtener credenciales válidas de dominio, un atacante puede desplazarse dentro de la red accediendo a múltiples dispositivos y servicios sin necesidad de explotar vulnerabilidades adicionales.

Se cumplen, por tanto, las tres condiciones establecidas para que exista una relación de tipo EXPLOTACIÓN entre estos dos nodos.

A la hora de asociar la secuencia de ataque generada con los activos del escenario, el comando `attack` extrae simultáneamente una serie de métricas acerca del ataque que ha tenido lugar. Estas estadísticas se presentan al terminar la ejecución a través de la terminal, organizadas en paneles de forma clara y jerárquica mediante la librería Rich. Este *dashboard* permite a los usuarios interpretar de manera rápida y eficaz los resultados del ataque simulado. La información mostrada es la siguiente, y se puede observar en la Figura 9.

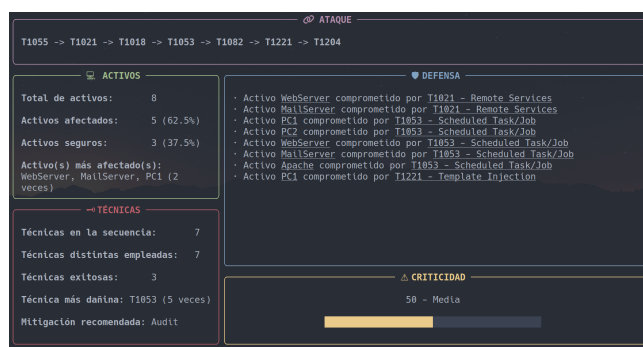


Figura 9. Resumen del ataque presentado sobre el escenario de oficina

- Panel ATAQUE: muestra la cadena de técnicas empleadas en el ataque. Las técnicas aparecen en orden y conectadas con flechas, lo que permite visualizar claramente cómo se ha desarrollado el ataque desde su inicio hasta su última fase.
- Panel DEFENSA: muestra una lista detallada en la que se indica, para cada activo comprometido, la técnica específica que lo ha vulnerado. Este panel proporciona información valiosa para identificar puntos débiles en la infraestructura y planificar medidas correctivas.
- Panel ACTIVOS: este panel proporciona una serie de estadísticas sobre los activos del escenario, permitiendo tener una visión clara del impacto del ataque sobre la infraestructura tecnológica. En concreto, se muestran las siguientes métricas:
 - Total de activos: número total de activos presentes en el escenario cargado.
 - Activos afectados: número y porcentaje de activos que han sido comprometidos por, al menos, una técnica.
 - Activos seguros: número y porcentaje de activos que no han sido vulnerados.
 - Activo(s) más afectado(s): de entre los activos afectados, activo o activos comprometidos por el mayor número de técnicas.
- Panel TÉCNICAS: este panel resume datos sobre las técnicas empleadas, lo que permite enfocar las medidas defensivas en los métodos de ataque más dañinos.

- Técnicas en la secuencia: número total de técnicas en la secuencia.
- Técnicas distintas empleadas: de entre las técnicas totales de la secuencia, número de técnicas que aparecen una única vez en ella.
- Técnicas exitosas: número de técnicas que han logrado comprometer, al menos, un activo.
- Técnica más dañina: identificador de la técnica que ha comprometido el mayor número de activos distintos.
- Mitigación recomendada: estrategia de defensa recomendada para paliar el impacto de la técnica más dañina.

- Panel CRITICIDAD: utilizando los datos anteriores, se le asigna una criticidad (C) de entre 0 y 100 al ataque, calculada como:

$$C = \left(\left\lfloor \frac{\text{Total activos afectados}}{\text{Total activos}} \times 50 \right\rfloor + \left\lfloor \frac{\text{Total técnicas exitosas}}{\text{Total técnicas empleadas}} \times 50 \right\rfloor \right)$$

Esta criticidad se visualiza mediante una barra de progreso coloreada de la siguiente forma:

- Verde (baja) si $C \leq 33$
- Amarillo (media) si $33 < C \leq 66$
- Rojo (alta) si $66 < C \leq 100$

VII. CONCLUSIONES Y LÍNEAS FUTURAS

El análisis de las rutas de ataque es uno de los puntos clave en la investigación de ciberseguridad actualmente. Para ello, la visualización del camino que este ataque puede recorrer dentro de una red resulta una herramienta eficaz para el estudio de los ciberataques con el objetivo de prevenirlos o mitigar su efecto dentro de entornos organizacionales. Al proporcionar una representación gráfica de los posibles recorridos de un atacante dentro de una red o sistema, se contribuye a la identificación de vulnerabilidades y la toma de decisiones estratégicas en seguridad, objetivos clave de los entornos de conciencia cibersituacional.

Los resultados obtenidos con ARGOS se complementan con el desarrollo de una estrategia de seguridad que permita abordar la respuesta frente a las amenazas a raíz de la caracterización de las técnicas utilizadas. El análisis de las rutas de ataque desde el punto de vista planteado en ARGOS permite identificar activos vulnerables, el impacto de los ataques y las contramedidas más eficaces; mientras que el estudio de los ataques para su caracterización, en este contexto, permite definir modelos más adaptados al comportamiento de los atacantes y que generen simulaciones más realistas.

Con el objetivo de mejorar la funcionalidad y el alcance de ARGOS, se presentan a continuación diversas líneas de desarrollo que podrían implementarse en versiones futuras de la herramienta. La implementación de estas mejoras permitiría que ARGOS se convierta en una herramienta más robusta y adaptable a las necesidades de análisis de seguridad en entornos de red.

Actualmente, ARGOS permite la carga de escenarios de red definidos mediante ficheros Cypher, pero la complejidad de estos escenarios podría ampliarse. Se podría considerar la integración de configuraciones más detalladas, incluyendo topologías de red dinámicas, segmentación de redes, o la

representación de defensas activas como sistemas de detección de intrusiones (IDS) y *firewalls*.

La simulación de ataques mediante Cadenas de Markov podría beneficiarse de una mayor personalización en la generación de secuencias de TTPs. Por ejemplo, podría incorporarse un sistema de pesos dinámicos basado en inteligencia de amenazas en tiempo real, permitiendo que las probabilidades de transición entre técnicas cambien en función de tendencias recientes en ataques reales. Otra posible mejora sería la incorporación de modelos probabilísticos más avanzados, como redes bayesianas, para mejorar la realismo de las transiciones entre estados.

En el estado actual, la herramienta almacena métricas sobre los ataques ejecutados, pero se podría ampliar la capacidad de análisis mediante la generación de informes automáticos con visualizaciones interactivas. El uso de librerías de análisis de datos como Pandas o herramientas de visualización como Dash podría permitir una exploración más intuitiva del impacto de los ataques en los activos del sistema.

Por último, el almacenamiento del historial de ataques podría enriquecerse con un sistema de versionado que permitiera comparar la evolución de escenarios a lo largo del tiempo. Además, se podría incluir un módulo de aprendizaje automático para identificar patrones en ataques previos y predecir posibles rutas de ataque futuras.

REFERENCIAS

- [1] Check Point: Cyberattacks targeting governments <https://www.checkpoint.com/es/cyber-hub/cyber-security/what-is-cybersecurity-for-governments/cyberattacks-targeting-governments/>. Último acceso: 17 de febrero de 2025.
- [2] Telefónica Tech: Tendencias en Ciberseguridad para 2025 <https://telefoniatech.com/blog/tendencias-en-ciberseguridad-para-2025>. Último acceso: 6 de febrero de 2025.
- [3] Plataforma Tecnológica Española de Tecnologías Disruptivas https://ptedisruptive.es/wp-content/uploads/2024/12/INFORME-DE-SITUACION_CIBERSEGURIDAD_2024.pdf. Último acceso: 6 de febrero de 2025.
- [4] Q. Wang, W. Wang, Y. Wang, J. Ren, B. Zhang: "Multi-Stage Network Attack Detection Algorithm Based on Gaussian Mixture Hidden Markov Model and Transfer Learning" en *IEEE Transactions on Automation Science and Engineering*, vol. 22, pp. 3470-3484, 2025.
- [5] Pilar Holgado, Víctor A. Villagrà, Luis Vázquez: "Real-Time Multistep Attack Prediction Based on Hidden Markov Model", en *IEEE Transactions on Dependable and Secure Computing*, vol. 17, n. 1, pp. 134-147, 2017.
- [6] M. A. R. A. Amin, S. Shetty, L. Njilla, D. K. Tosh, C. Kamhoua: "Hidden Markov Model and Cyber Deception for the Prevention of Adversarial Lateral Movement", en *IEEE Access*, vol. 9, pp. 49662-49682, 2021.
- [7] S. Dass, P. Datta, A. S. Namin: "Attack Prediction using Hidden Markov Model", en *2021 IEEE 45th Annual Computers, Software, and Applications Conference (COMPSAC)*, pp. 1695-1702, 2021.
- [8] Fuxiong Sun, Juntao Pi, Jin Lv, Tian Cao: "Network Security Risk Assessment System Based on Attack Graph and Markov Chain", en *Journal of Physics: Conference Series*, 910, 2017.
- [9] Ricardo M. Czekster, Charles Morisset: "BDMPathfinder: a tool for exploring attack paths in models defined by Boolean logic Driven Markov Processes", en *2021 17th European Dependable Computing Conference (EDCC)*, pp. 83-86, 2021.
- [10] The Mitre Corporation: MITRE ATT&CK <https://attack.mitre.org/>. Último acceso: 10 de enero de 2025.
- [11] Universidad Politécnica de Madrid: Cadenas de Markov https://dcain.etsin.upm.es/~carlos/bookAA/04.02_CadenasMarkovResultados.html. Último acceso: 10 de marzo de 2025.
- [12] Becca Gomby: What Is An Attack Path & How Does It Help Identify Risks? <https://www.panoptica.app/blog/what-is-an-attack-path-how-does-it-help-identify-risks>. Último acceso: 30 de enero de 2025.

- [13] Picus Labs: What Is Attack Path Visualization? <https://www.picussecurity.com/resource/glossary/what-is-attack-path-visualization>.
Último acceso: 30 de enero de 2025.